Annexe 2 — Critères d'acceptabilité d'une AIPD

Les critères suivants proposés par le GT29 peuvent être utilisés par les responsables du traitement pour déterminer si une AIPD ou une méthodologie d'AIPD considérée est suffisamment complète aux fins du respect des exigences du RGPD:

- ☐ une description systématique du traitement est fournie [article 35, paragraphe 7, point a)]:
  - ☐ la nature, la portée, le contexte et les finalités du traitement sont pris en compte (considérant 90);
  - ☐ les données à caractère personnel concernées, les destinataires et la durée pendant laquelle les données à caractère personnel seront conservées sont précisés;
  - ☐ une description fonctionnelle de l'opération de traitement est fournie;
  - ☐ les actifs sur lesquels reposent les données à caractère personnel (matériels, logiciels, réseaux, personnes, documents papier ou canaux de transmission papier) sont identifiés;
  - ☐ le respect de codes de conduite approuvés est pris en compte (article 35, paragraphe 8);
- ☐ la nécessité et la proportionnalité sont évaluées [article 35, paragraphe 7, point b)]:
  - ☐ les mesures envisagées pour assurer la conformité au règlement sont déterminées [article 35, paragraphe 7, point d), et considérant 90], avec prise en compte:
    - ☐ de mesures contribuant au respect des principes de proportionnalité et de nécessité du traitement, fondées sur les exigences suivantes:
      - ☐ finalités déterminées, explicites et légitimes (article 5, paragraphe 1, point b)];
      - ☐ licéité du traitement (article 6);
      - ☐ données adéquates, pertinentes et limitées à ce qui est nécessaire [article 5, paragraphe 1, point c)];
      - ☐ durée de conservation limitée [article 5, paragraphe 1, point e)];
    - ☐ de mesures contribuant aux droits des personnes concernées:
      - ☐ informations fournies à la personne concernée (articles 12, 13 et 14);
      - ☐ droit d'accès et droit à la portabilité des données (articles 15 et 20);
      - ☐ droit de rectification et droit à l'effacement (articles 16, 17 et 19);
      - ☐ droit d'opposition et droit à la limitation du traitement (articles 18, 19 et 21);
      - ☐ relations avec les sous-traitants (article 28);
      - ☐ garanties entourant le ou les transferts internationaux (chapitre V);
      - ☐ consultation préalable (article 36);
- ☐ les risques pour les droits et libertés des personnes concernées sont gérés [article 35, paragraphe 7, point c)]:
  - ☐ l'origine, la nature, la particularité et la gravité des risques sont évalués (considérant 84) ou, plus spécifiquement, pour chaque risque (accès illégitime aux données, modification non désirée des données, disparition des données) du point de vue des personnes concernées:
    - ☐ les sources de risques sont prises en compte (considérant 90);
    - ☐ les impacts potentiels sur les droits et libertés des personnes concernées sont identifiés en cas d'événements tels qu'un accès illégitime aux données, une modification non désirée de celles-ci ou leur disparition.
    - ☐ les menaces qui pourraient conduire à un accès illégitime aux données, à une modification non désirée de celles-ci ou à leur disparition sont identifiées;
    - ☐ la probabilité et la gravité sont évaluées (considérant 90);
  - ☐ les mesures envisagées pour faire face à ces risques sont déterminées [article 35, paragraphe 7, point d), et considérant 90];
- ☐ les parties intéressées sont impliquées:
  - ☐ l'avis du DPD est recueilli (article 35, paragraphe 2);